

Cadre de cohérence technique

Annexe SSO

Gestion des authentifications et des autorisations d'accès
aux applications du ministère de l'intérieur

Mises à jour du document		
Date	Objet	Auteur
2018-03-01	Ajout chapitre PASSAGE	Jacques Labidurie
2018-03-20	Remise en forme document avec un document chapeau renvoyant vers des offres de service séparées	Jean-Charles Bastoul et Alain Barbay
2018-04-24	Simplification du contenu et description des modes de fonctionnement de chaque SSO	Jean-Charles Bastoul et Alain Barbay
2018-05-09	Corrections mineures	Jérémy Kespite (ST(SI) ²)
2018-06-01	Corrections sur le périmètre FranceConnect Agent (pas limité à l'Etat)	Alain Barbay

Table des matières

A - Contexte général de la gestion des authentifications et des autorisations d'accès au ministère de l'intérieur.....	4
B - Architecture générale des SSO du ministère.....	7
1 -Les composantes de la solution.....	7
2 -Les modes de fonctionnement – Vue utilisateur.....	8
3 -Modes de prise en charge des applications.....	8
3.1 -Mode délégué – Avec reverse proxy.....	9
3.2 -Mode direct – L'application parle au SSO.....	9
4 -Un SSO pour les clients lourds.....	10
5 -Cas des applications locales.....	10
5.1 -Mode direct.....	10
5.2 -Mode délégué.....	10
6 -Prise en charge des terminaux mobiles.....	11
7 -Fédération à l'échelon des administrations : FranceConnect Agent.....	11
C - Les offres de service.....	12

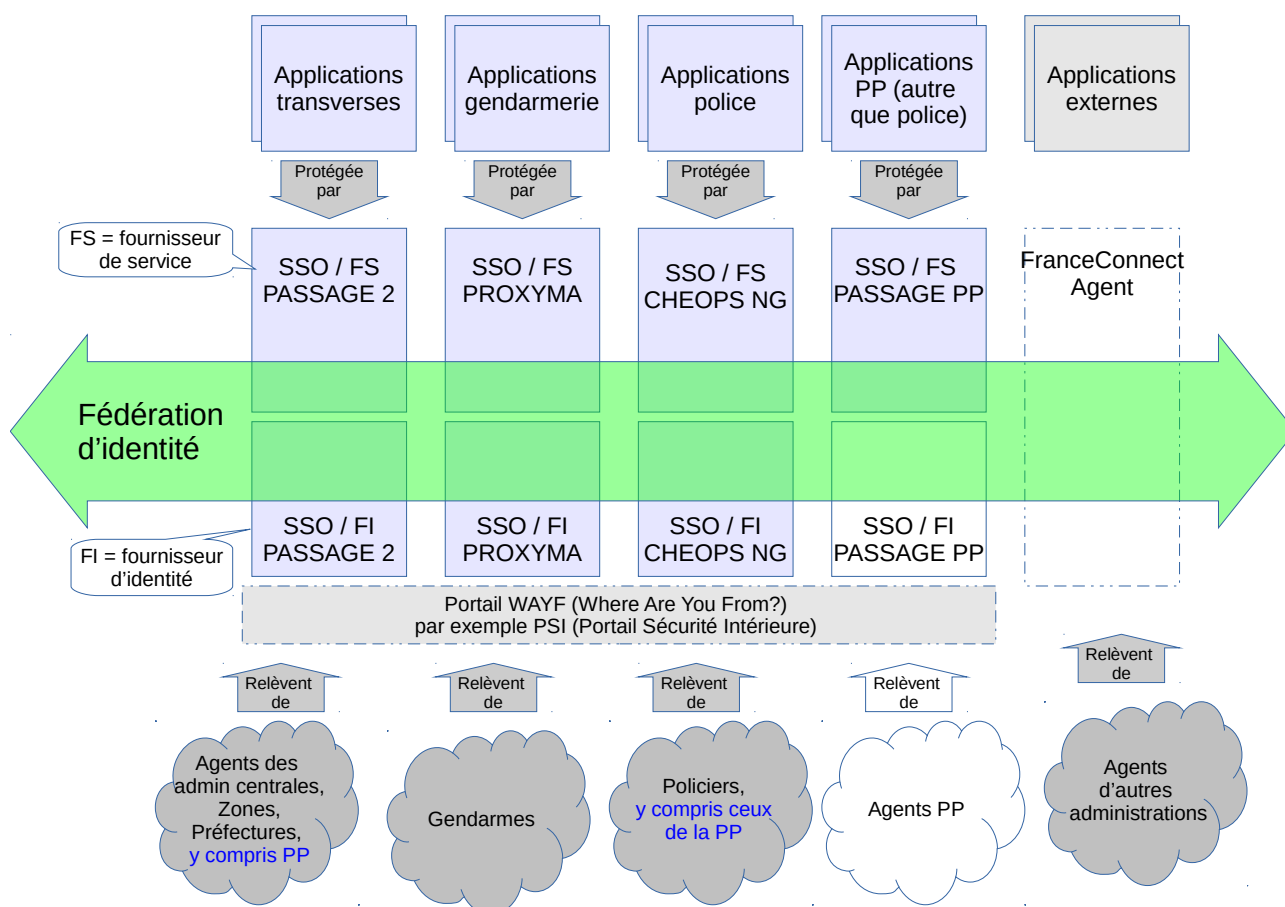
A - Contexte général de la gestion des authentifications et des autorisations d'accès au ministère de l'intérieur

La majorité des applications nécessitent les trois fonctions d'identification, d'authentification et de contrôle de l'accès de leurs utilisateurs. Chaque application peut gérer elle-même ces trois fonctions, mais il est bien plus judicieux de les déléguer à un **système d'authentification unique, ou SSO (Single Sign On)**. L'utilisateur une fois identifié et authentifié, obtient un jeton qui va lui permettre d'accéder, avec les droits qui lui ont été reconnus, à toutes les applications ayant délégué ces fonctions.

Très schématiquement, un SSO peut se décomposer en deux parties :

- le « Fournisseur de service » (FS) qui protège les applications.
- l' « Fournisseur d'identité » (FI) qui identifie, authentifie et attribue des droits aux utilisateurs pour l'accès à ces applications protégées.

Ce découpage du SSO en FS / FI apparaît sur le schéma qui suit.



Pour des raisons historiques, le ministère de l'intérieur a mis en place 4 SSOs, qui apparaissent sur le schéma :

- le SSO de la gendarmerie PROXYMA
qui protège les applications de la gendarmerie (fonction FS)
et prend en charge la population des gendarmes (fonction FI)
- le SSO de la police CHEOPS NG
qui protège les applications de la police
et prend en charge la population des policiers
- le SSO de la préfecture de police PASSAGE PP
qui protège les applications de la PP
et prend en charge les agents de la PP.

Il est à noter que dans la cible stratégique validée en COREP de juillet 2016, PASSAGE PP **garderait sa fonction de fournisseur de service mais perdrait sa fonction de fournisseur d'identité** : en effet, pour que chaque population ne dépende que d'un unique SSO, les policiers de la PP relèveraient plutôt du SSO de la police CHEOPS NG, et les autres agents de la PP, par exemple des agents de la mairie de Paris, seraient appelés à être pris en charge par PASSAGE 2.

- et le SSO des services transversaux PASSAGE 2
qui protège les applications transverses
pour le compte des agents « administratifs » des services centraux, des zones de défense, des préfectures.

Ces 4 principaux SSO sont en « **fédération d'identité** ». Concrètement, cela signifie qu'un utilisateur identifié et authentifié par son SSO de rattachement (normalement unique) peut accéder à une application contrôlée par un autre SSO du ministère pourvu qu'il en ait les droits. Par exemple un policier peut accéder à une application transverse relevant du SSO PASSAGE2, en se faisant authentifier par le SSO dont il relève, en l'occurrence, CHEOPS NG.

A ces 4 SSO fédérés et internes au ministère, il faut ajouter **FranceConnect Agent**, qui est en cours de déploiement. FranceConnect Agent est un SSO de l'administration, qui doit permettre à tout agent des fonctions publiques de l'État, territoriale et hospitalière d'accéder à des applications d'une autre administration que la sienne. FranceConnect Agent est appelé à entrer dans la fédération des SSO du ministère. A ce stade, les détails du raccordement avec FranceConnect Agent ne sont pas encore arrêtés au MI.

Le schéma fait également apparaître une fonction dite WAYF (Where Are You From?). Cette fonction devient nécessaire lorsque qu'un utilisateur non encore authentifié veut accéder directement à une application. Celle-ci ne connaissant pas le SSO dont relève l'utilisateur le redirige cette page lui permettant de choisir son SSO.

La copie d'écran qui suit montre la page d'accueil de l'un de ces portails, avec les boutons des 4 SSO du ministère.

Fichier Édition Affichage Historique Marque-pages Outils ?

documentation:lemonldap... x Portail PSI x +

https://auth.sso.psi.minint.fr Recherche

La Poste Envol S OnlyOffice Forge DSIC SASWIKI COMU MGMSIC JOOMLA Annuaire Casper CANEL Canel / M

Portail de la Sécurité Intérieure

Accès Gendarmerie Nationale	Accès Police Nationale	Accès Préfecture de Police	Accès Préfectures
			

☐ Voir mes dernières connexions

Des données nominatives vous concernant sont enregistrées pendant votre connexion. En vertu de la loi n°78-17 du 6 janvier 1978 « Informatique et Libertés », vous disposez d'un droit d'accès et de rectification de ces données. Pour exercer ce droit, adressez-vous au ST(SI)² / SDAC / BCOF par la voie hiérarchique.

B - Architecture générale des SSO du ministère

1 - Les composantes de la solution

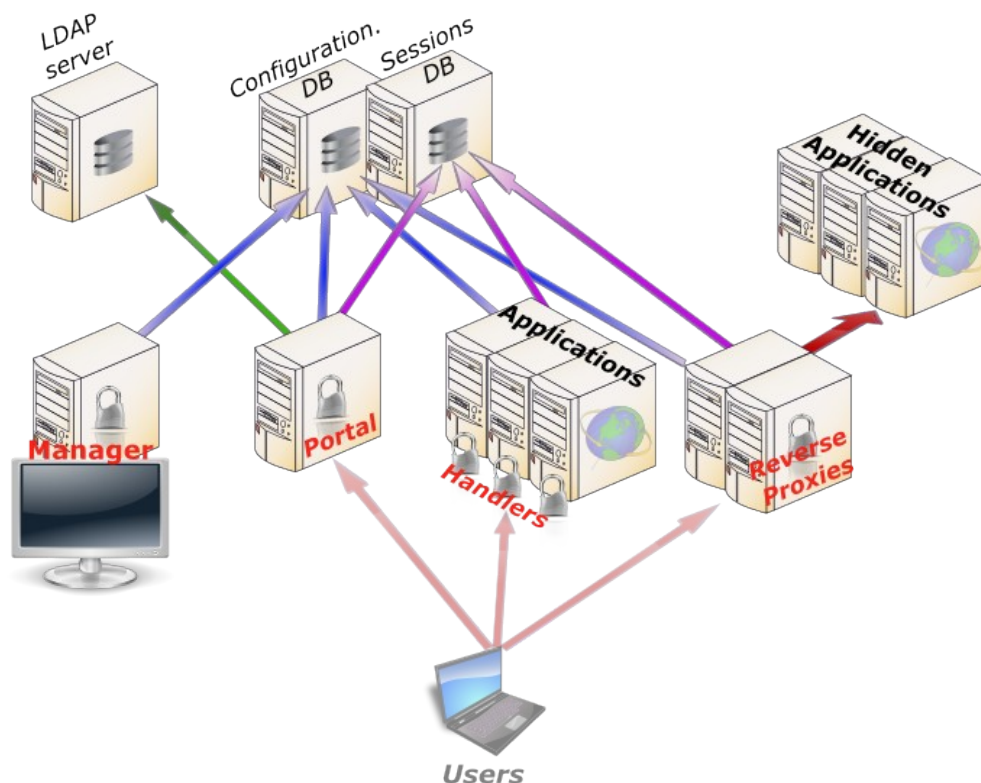
Tous les SSO du ministère sont bâtis autour du même composant de base : **LemonLDAP::NG**. A quelques variantes près, ils partagent donc tous les mêmes caractéristiques qu'ils héritent du composant commun.

Le composant est documenté sur le site <http://lemonldap.ow2.org>.

LemonLDAP::NG est avant tout un SSO « web », il s'adresse principalement à des applications web, c'est-à-dire des applications fonctionnant avec un navigateur.

Néanmoins LemonLDAP::NG peut être également utilisé dans un contexte d'application client/serveur. Dans la pratique, cette fonctionnalité marginale n'est pas mise en œuvre dans tous les SSOs du ministère : seul PROXYMA l'utilise.

Le site de description du composant LemonLDAP::NG fournit le schéma de principe suivant :



La fonction de gestion des droits d'accès n'est par contre pas réalisée par le composant commun LemonLDAP::NG. Chaque porteur de SSO la réalise à sa façon et avec des composants différents. Ainsi, CHEOPS NG s'appuie sur l'outil historique de gestion des habilitations (GEHA),

PROXYMA dispose de l'application GEDRAC, PASSAGE PP s'appuie sur GHABI et PASSAGE 2 a recours à la solution commerciale MRM. Les modes de gestion de ces droits d'accès sont parfois très différents. La Gendarmerie calcule la majorité des droits à partir des caractéristiques de l'utilisateur (affectation, compétences, fonction...) enregistrées dans le SIRH, et ne fait du discrétionnaire que de manière exceptionnelle. A l'opposé, PASSAGE 2, a plutôt recours à des droits discrétionnaires. Quelle que soit la solution de gestion de droits employée, elle alimente l'annuaire du SSO.

2 - Les modes de fonctionnement – Vue utilisateur

Deux modes de fonctionnement sont possibles

- **mode à flux traversant** : l'utilisateur accède à ses applications au travers d'un portail, que ce soit pour la phase d'identification / authentification / autorisation ou pour la phase de dialogue avec son application. Dans ce mode, le portail relaie l'ensemble des flux entre l'utilisateur et son application.
- **mode à flux direct ou non traversant** : l'utilisateur adresse directement son application, s'il n'est pas encore identifié, il est redirigé temporairement vers le portail d'identification / authentification / autorisation, mais une fois que sa session est créée et qu'il a obtenu son jeton, les flux sont directs entre le navigateur client et le serveur et ne transitent plus par le portail.

Le mode traversant peut présenter des inconvénients, d'une part en termes de performance (concentration des flux sur le même composant, à dimensionner correctement) et en termes de périmètre de déploiement : le mode traversant est un modèle très centralisé qui est plus difficile à déployer avec des applications locales ou des centres d'hébergements régionaux.

Les deux modes co-existent dans les systèmes déployés au ministère.

3 - Modes de prise en charge des applications

Ce sujet concerne tout particulièrement le chef de projet qui doit inscrire son application dans le SSO dont elle relève.

Une application doit dialoguer avec le SSO : elle doit rediriger vers le portail SSO les utilisateurs ne détenant pas encore de jeton d'authentification, (éventuellement vers une page de WAYF pour le choix du SSO approprié), puis, pour les utilisateurs autorisés, récupérer leur identité et leur profil de droits. Deux modes sont possibles avec plus ou moins d'impact pour l'application :

- **Mode délégué.**
Tous les échanges SSO sont pris en charge par un « **reverse proxy applicatif** » (RPA).
L'application reçoit directement les informations utiles (identité, droits) sous forme d'entêtes http. Le RPA est une composante de l'infrastructure SSO et celle-ci peut être mutualisée pour plusieurs applications.

- **Mode direct.**

Dans ce mode, il n'y a pas de délégation, ni de reverse proxy, c'est à l'application elle-même de prendre en charge tous les échanges avec le SSO.

3.1 - Mode délégué – Avec reverse proxy

Le mode délégué, avec reverse proxy, est le plus simple du point de vue intégration. Malheureusement c'est aussi le mode de fonctionnement le plus limité, notamment du point de vue des applications locales et des sites d'hébergements régionaux.

3.2 - Mode direct – L'application parle au SSO

Une première question à se poser est celle de la « langue », ou protocole, dans laquelle cet échange se fait. Il y a en a plusieurs :

- dialecte natif de LemonLDAP::NG ;
- le protocole normalisé SAML ;
- le protocole OpenID Connect.

La seconde question est celle du handler ou de l'agent applicatif qui prendra en charge cet échange. Ici aussi il y a plusieurs possibilité :

- Le **handler LemonLDAP::NG** qui peut être installé sur le serveur de présentation de l'application. Il s'agit d'un module apache, ce qui restreint son utilisation à un frontal apache (un frontal NGINX n'est pas supporté). Le handler LemonLDAP::NG peut parler plusieurs protocoles, LemonLDAP, SAML, [CAS, OpenID Connect].
- Un **module apache SAML, par exemple auth_mellon**. Cette solution est proposée par l'équipe PASSAGE2.
- Au-delà de ces deux exemples, de nombreux logiciels ou progiciels sont capables de prendre en charge de façon paramétrable le rattachement à un SSO, en utilisant l'un des protocoles standard SAML, CAS, OpenID Connect (par exemple Alfresco ou Maarch).

Au ministère, les protocoles LemonLDAP::NG et SAML sont privilégiés. Toutefois, l'arrivée de FranceConnect, va y ajouter l'usage de OpenId Connect.

4 - Un SSO pour les clients lourds

Ce mode d'accès n'est mis en œuvre que dans le SSO PROXYMA.

Une application utilisant un client autre que le navigateur (client lourd) peut déléguer l'authentification au portail LemonLDAP::NG par service SOAP : le client applicatif soumet le login et le mot de passe de l'utilisateur au portail, qui ouvre une session et retourne un cookie de session.

Ce cookie de session doit alors être présenté par le client à chaque requête au serveur de l'application. De même que pour une application web, ce serveur peut être protégé par un agent SSO configuré localement ou sur un reverse-proxy, qui peut propager les attributs de l'utilisateur et contrôler l'accès à l'application dans les mêmes conditions que précédemment. Le serveur de l'application peut également assurer lui-même ces fonctions en invoquant les services SOAP du portail présentés plus haut.

De plus, sur présentation du cookie de session le client peut lui aussi demander au portail les attributs de l'utilisateur.

Le client ne doit pas garder en mémoire le mot de passe de l'utilisateur ; fermé, il ne doit pas garder en mémoire le cookie de session.

5 - Cas des applications locales

On appellera ici application locale une application hébergée en dehors des sites d'hébergement nationaux dans lesquels sont localisés les infrastructures du SSO.

5.1 - Mode direct

Un SSO supportant le mode direct (quelques-fois appelé mode SAML) dans lequel le navigateur, après la phase d'identification / authentification / autorisation, peut dialoguer directement avec l'application ne pose pas de problème particulier pour l'application locale. A condition toutefois que celle-ci supporte le mode SAML, ou qu'elle soit interfacée localement par un reverse proxy SAML.

5.2 - Mode délégué

Si l'on souhaite - ou si on doit - utiliser le mode à flux traversant, l'intégration d'une application locale est plus problématique en termes de gestion des flux comme en termes de performances. La solution préconisée par le ST(SI)² consiste à utiliser un portail d'authentification local, subordonné au portail SSO central. Le mode de fonctionnement est analogue à celui décrit dans la section précédente (SSO pour les clients lourds) et utilise un web service SOAP. Ce mode de fonctionnement est détaillé dans l'offre de service du ST(SI)².

6 - Prise en charge des terminaux mobiles

Le cas le plus simple est celui d'une application web protégée par un SSO. Le terminal mobile (Neo, Hesperis, CALLME ..) peut y accéder, sans difficulté particulière, à condition toutefois de supporter le mode d'authentification par carte agent si celui-ci est imposé par l'application, et si celle-ci souhaite une authentification de niveau élevé.

Le cas d'une **application mobile** est plus complexe, mais il nous ramène à celui des clients lourds traité dans la section 4 qui précède. Le même mode opératoire peut être utilisé.

Mais un terminal Android sait aussi parler nativement le protocole OpenID Connect et cette éventualité pourra être envisagée dans le futur.

7 - Fédération à l'échelon des administrations : FranceConnect Agent

La DINSIC a conçu un système de fédération d'identité qui se décline en trois instances :

- FranceConnect particulier (hors périmètre de cette annexe)
- FranceConnect entreprise (à l'étude à la date d'écriture de ce document)
- FranceConnect Agent

FranceConnect Agent apporte aux SSO internes la brique permettant d'élargir la fédération d'identité à l'ensemble des agents de l'État : FranceConnect Agent permet aux agents du ministère de l'intérieur d'accéder à des applications externes et inversement à des agents d'autres administrations d'accéder à des applications hébergées au sein du ministère de l'intérieur. Dans cette fédération élargie, nos SSO internes fonctionnent comme fournisseurs d'identité pour FranceConnect Agent.

Techniquement, FranceConnect, dans ses trois déclinaisons, s'appuie sur le protocole standard **OpenID Connect**. Ce protocole est aussi celui utilisé par un grand nombre de sociétés de l'Internet, Facebook, Google, LinkedIn ...etc.

A l'instant de l'écriture du présent document, l'interfaçage de FranceConnect Agent avec les SSO du ministère et l'impact sur les applications internes n'est pas pleinement évalué. Idéalement, les applications internes n'auront pas besoin d'implémenter OpenID Connect pour bénéficier des services de FranceConnect Agent et c'est le SSO ministériel auquel elles sont attachées qui prendra en charge l'interfaçage avec le protocole. Mais il se peut que cela ne soit pas toujours possible, et que dans des cas d'usage encore à définir, l'application soit contrainte de prendre en charge directement le protocole OpenID Connect.

C - Les offres de service

Domaine	Informations utiles
URL des SSO	Portail Sécurité Intérieure : https://auth.sso.psi.minint.fr/ SSO PROXYMA : https://auth.sso.gendarmerie.fr/ SSO CHEOPS NG: https://auth.sso.police.fr/ SSO PASSAGE PP: https://auth.sso.ppol.minint.fr/ SSO PASSAGE2: https://auth.sso.minint.fr/
Contacts utiles	Les contacts sont renseignés dans les offres de service.
Offres de service	Offre de service pour les SSO de la sécurité intérieure (ST(SI)² / PROXYMA, CHEOPS NG et PSI) : offre ST(SI)² Le ST(SI)² donne également la possibilité de mettre en place un portail d'authentification pour les applications locales : http://auth.local.gendarmerie.fr/info.html ----- Offre de service pour le SSO de la PP (PASSAGE PP) : http://wiki.sdsic.ppol.mi/lib/exe/fetch.php?media=referentiel:offre_de_service_passage_pp.pdf ----- Offre de service pour le SSO transversal (DSIC / PASSAGE 2) : • offre de service : http://dsic.minint.fr/images/CatalogueServices/05.01_Fiche_catalogue_PASSAGE2_V1.pdf • documents d'intégration : à venir • contacts : directeur de projet, ... ----- Offre de service DINSIC pour l'intégration de FranceConnect Agent : cette offre de service est attendue pour juin 2018, mais des informations de même nature peuvent être trouvées aux adresses suivantes : • https://api.gouv.fr/api/franceconnect.html • https://franceconnect.gouv.fr/
Zone d'entraide	Le ST(SI) ² fournit pour le portail d'authentification pour les applications locales un forum ouvert aux gendarmes : forum dédié